

Part 3. Human-Centred Security

Oliver Wright

2203984

1. Human-Centred Risks

According to Almeida (2025) 88% of cyberattacks have human origins, with social engineering and phishing remaining the most common entry points. As a result, humans are considered the weakest link in cybersecurity, with most attacks involving human error. Phishing is defined as “a type of cyberattack where attackers masquerade as trusted sources to steal sensitive information. These attacks work by deceiving individuals into providing information through fake messages designed to look authentic” (Microsoft, n.d.). The number of unique phishing attacks identified has increased over the years, peaking at over 1.6 million in quarter 1 of 2023 (*Figure 1*).

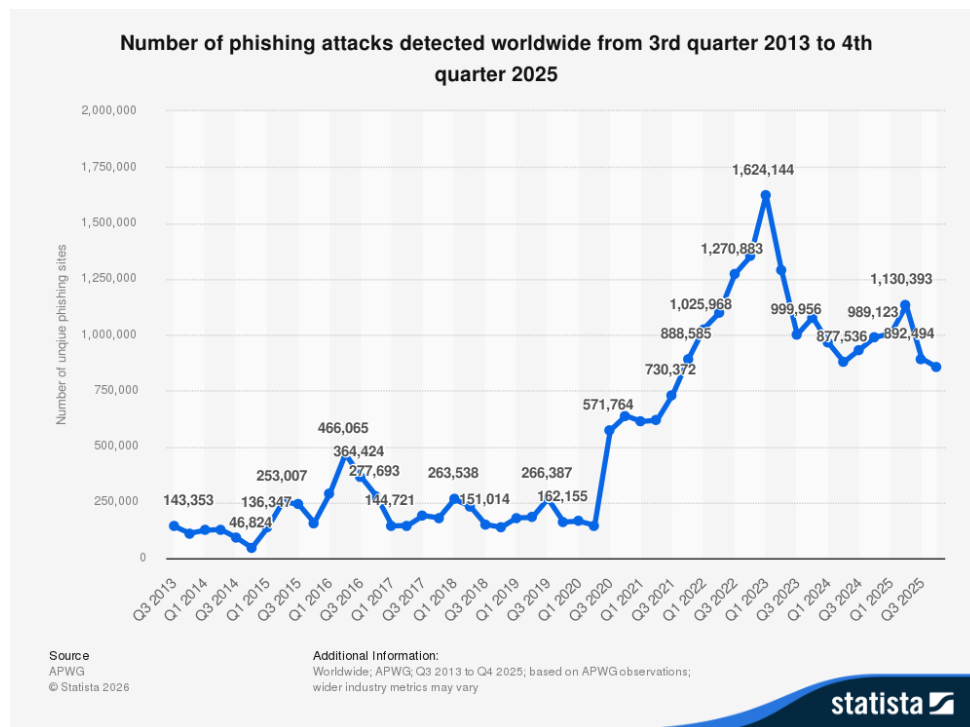


Figure 1 Number of unique phishing attacks (Statista Research Department, 2026)

The attack's success highly depends on the target being tricked or manipulated into disclosing sensitive information. Additionally, “social engineering may be used to target specific high-value individuals or groups in the organisation, such as executives, or may have a broad target set” (Scarfone et al., 2008). For a phishing attack to be successful, the attacker usually creates a credible, trusted persona. This can be attributed to two primary tactics: the imitation of an already trusted individual or authority, and the cultivation of a relationship with the victim to create the illusion of trust (Which?, 2022). Cybersecurity experts have difficulty solving this issue because it is a psychological one in a cybersecurity context. Attackers exploit well-documented psychological principles to manipulate victims, including reciprocity, scarcity, authority, commitment and consistency, liking, and consensus (Cialdini, 1984). Furthermore, Jagatic et al. (2007) demonstrated that targeted phishing attacks using contextual information drastically increase success rates. This makes ScottishGlen's situation of being targeted by a hacktivist group particularly alarming. The consequences of falling victim to a successful phishing attack can be costly in various ways. Phishing attacks often lead to data breaches, which can result in financial costs from fines and legal fees, and reputational damage, losing the trust of employees, users, and shareholders.

2. Human-Centred Recommendations

The primary solution to preventing phishing attacks is to improve educational materials and raise awareness. While most people working at companies would not share information unprompted, attackers have begun leveraging psychological principles to manipulate their targets. Therefore, it can be difficult to identify an attacker due to the illusion of trust, authority, or urgency.

To counter this, education needs to be provided on a regular basis to prevent employees from forgetting about their phishing training over time. Employees should be taught the specific tactics deployed by attackers and tells they can use to identify a suspicious email or interaction. *Figure 2* displays some of the tells present in phishing emails involving: psychological tactics of pushing a sense of urgency on the victim, generic messages often not directly referencing the victim or the specifics of the problem, a consequence of not performing the attacker's desired outcome, and external web links.

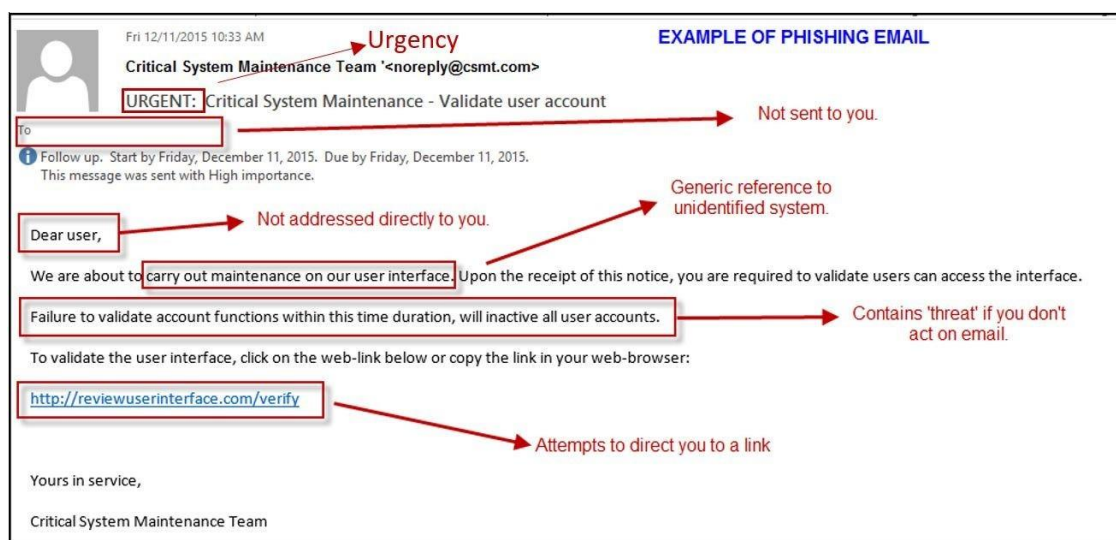


Figure 2 Annotated example of phishing email and suspicious tells (Bhatt, 2023)

Upon identifying a potential phishing email or deceptive interaction, employees should follow a procedure for reporting it. Education like this can reduce the overall success rate of the attack and encourage a blameless culture of reporting phishing emails. When successfully cultivated, such an environment helps prevent employee embarrassment or fear of punishment for falling for phishing emails, allowing them to report the attack without repercussions. Another way to help employees identify suspicious emails and interactions is to develop clear communication policies to be followed. Attackers would need to know these internal policies before they can create convincing phishing emails. This also further distances legitimate interactions from the more common generic phishing emails, as they will not follow the company communication policies, making them more identifiable.

Simulated phishing exercises build awareness by reinforcing behaviour in practice. Since Jagatic et al. (2007) demonstrated that contextual, targeted phishing is far more effective than generic attempts, ScottishGlen's simulated attacks should be tailored to mirror the tactics used in the hacktivist group's phishing attacks. This would help employees identify threats that are more relevant than generic phishing attacks. The downside of simulated attacks is the potential for employee embarrassment and loss of trust. Employees may feel targeted when confronted; therefore, it is important to frame it as a learning experience rather than an assessment.

Password practice education is also an important aspect of employee account security. Seeing as a password is a secret that only the employee it belongs to knows, it is extremely difficult to actively assess the strength of employee passwords without breaching their privacy. While technical controls can be implemented to ensure that the password meets specific requirements, this does not always solve the problem, as employees may reuse passwords from other platforms or follow commonly and easily predictable password patterns. Therefore, employees should be encouraged to come up with an easily remembered passphrase, focusing on character length rather than specific character type requirements. This should not be reused for any other service to prevent data breaches of external services from jeopardising their ScottishGlen work account. Employees should be educated on the risks associated with writing down their passphrase and encouraged to use a password manager in scenarios where memorisation is not an option.

However, even when attempting to closely follow precautions, the research of Jalali et al (2020) shows that employees still fall victim to clicking phishing links, citing a positive correlation to their workload. Employees are often overworked in high-stress environments, and this can lead to clouded judgment for just a second, resulting in a successful phishing attack. Therefore, it is important to consider employee workload and overall health within the work environment. Additionally, email filtering and other technical controls should complement these human-centred precautions. These help provide a layer of security in situations where employees are distracted for any reason.

3. Authentication Mechanisms

Authentication is the method of determining whether someone is who they say they are. According to Cornell University (Cornell University, n.d.) there are three mechanisms for authenticating humans: “something you know” (e.g., a password), “something you have” (e.g., an access card), and “something you are” (e.g., a fingerprint).

Passwords are the most predominant form of authentication present in most systems. A password uses a secret that only the user knows to authenticate themselves. Despite being its predominance, there are major issues with password authentication, especially when used in solidarity. Lamport (1981) states that an intruder could learn a user’s secret password by extracting it from an exploited system, intercepting the user’s communication (verbal eavesdropping or keylogger), or inadvertent disclosure of the password (social engineering or use of an easily guessed password). Another human-centred problem with password security is the increasingly complex requirements to make it secure and the unrealistic demand placed on users. “Inevitably, users will devise their own coping mechanisms to cope with ‘password overload’. This includes re-using the same password across different systems, using simple and predictable password creation strategies, or writing passwords down where they can be easily found” (National Cyber Security Centre, 2019).

The second mechanism of authentication relies on something within the user’s possession. This comes in the form of an access card, often for locational authentication or digital authentication through SMS. DogTownMedia (2026) compares SMS and authenticator apps and concludes that SMS is a much weaker form of authentication due to its susceptibility to SIM-swap attacks and other network vulnerabilities, whereas authenticator apps generate codes locally, eliminating these vulnerabilities.

The final authentication mechanism refers to biometric identification, which uses the user’s human characteristics, such as their face, fingerprints, and iris. Biometric authentication has the advantages of being much harder to exploit and being unable to be lost, forgotten, or shared with others. However, the disadvantages are considerably strong, including hefty financial investments and extreme user privacy concerns (Boatwright & Lou, 2007).

Different circumstantial factors determine which authentication mechanisms are strongest for the specific use case. Temoshok et al. (2025) further explains the potential combinations of these required for a suitable level of security, “when a combination of two single-factor authenticators is used, the combination SHALL include one physical authenticator (i.e., “something you have”) from the following list in conjunction with either a password [...] or a biometric comparison”. The process of using more than one of these mechanisms for authentication is called multi-factor authentication (MFA). Previous data breaches through phishing attacks have proven that attackers target platforms or users without MFA enabled. The cloud data analytics platform “Snowflake” began enforcing MFA on user accounts after identifying this trend among its users and learning that a threat actor had obtained credentials belonging to a former Snowflake employee (Vigliarolo, 2024).

Despite the high level of security provided by MFA, the practice is often frowned upon by end users due to the extra steps it introduces. “Such methods require the user to own a specific piece of hardware, which generates a dynamic one-time password (OTP) required for authentication. However, this is considered burdensome both for the user and the service provider as it introduces the need to always carry that device and incurs additional costs” (Aldea, 2025). Additionally, the National Cyber Security Centre (2024) states common MFA anti-patterns: bypass by legacy protocols, backdoor by excluded accounts, and time-based re-authentication. Neglecting to ensure

these are excluded from MFA can leave organisations with a worse security posture than before MFA implementation.

4. Authentication Recommendations

The recommended implementation to suit ScottishGlen's conditions would be a combination of enforced strong passwords and a time-based one-time password (TOTP) authenticator app. This combines the "something you know" and "something you have" forms of authentication to create a multi-factor solution. While biometric authentication is considered potentially more secure than every other form of authentication, the downsides (financial demands and privacy concerns) and ScottishGlen's limited budget largely outweigh the benefits.

When implementing enforced strong password authentication, it is important to find the right balance of security and complexity. The level of complexity must be high enough to prevent the user from using easily guessed passwords and should encourage them not to reuse their passwords from other services. However, studies have shown that password requirements with too much complexity places and unrealistic demand on users, resulting in them developing coping mechanisms to overcome it, including password reuse, standardised password creation patterns, or documenting plaintext passwords on paper or notepad software. Therefore, the system should encourage password length rather than overly specific character requirements, having users create passphrases to counter brute force attacks.

A TOTP authenticator app should be developed for users to install on their mobile phones, as this essentially eliminates network-based exploits. While SMS authentication is easier to implement and has less strain on usability, the various vulnerabilities it harbours hinder the security posture that this second level of authentication provides. Upon a valid account name and password login, a unique code should be generated on the user's authenticator app and should automatically expire after one minute. The app should be built avoiding common MFA anti-patterns, primarily ensuring no legacy protocol bypasses exist.

Despite how commonly it is found in the modern cyber landscape, research shows that credentials alone are insufficient protection. While multi-factor authentication can cause friction for employees due to the extra steps it introduces, it is necessary for a modern, secure system capable of responding to the threat ScottishGlen is facing. Overworked employees were found to have increased susceptibility to phishing attacks and social engineering; therefore, the authentication should not implement more than two levels to remain as frictionless as possible while upholding security. Finally, Bonneau et al. (2012) established that authentication schemes must be evaluated across three criteria: usability, deployability, and security, and that no single scheme satisfies all three of these simultaneously. The combination of enforced strong passwords and a TOTP authenticator app provides a harmonic balance across these criteria. Passwords provide familiarity and zero deployment cost, and a TOTP app adds significant security with minimal infrastructure investment and the option of using reputable open-source libraries for efficient development, suiting ScottishGlen's limited budget. Having an extra layer of security prevents intruders from accessing an account, even with stolen credentials. Logins that fail at the authentication stage can be tracked as suspicious behaviour to help identify when an account is being targeted. This massively reduces the risk posed by phishing and social engineering attacks, helping address the cybersecurity weaknesses caused by human error.

5. References

- Aldea, C. L. (2025). Authentication Challenges and Solutions in Microservice Architectures. *Applied Sciences*, 15(22). doi:10.3390/app152212088
- Almeida, A. (2025, September 5). *Human Weaknesses in Cybersecurity 2025: Risks, Facts, and Solutions*. Retrieved from HeyData: <https://heydata.eu/en/magazine/human-weaknesses-in-cybersecurity-2025-risks-facts-and-solutions/>
- Bhatt, P. (2023, November 10). *How to investigate a Phishing Email? A step-by-step guide !* Retrieved from OSINT Team: <https://osintteam.blog/how-to-investigate-a-phishing-email-a-step-by-step-guide-82b7976661cd>
- Boatwright, M., & Lou, X. (2007). What do we know about biometrics authentication? *Proceedings of the 4th annual conference on Information security curriculum development* (pp. 1-5). Kennesaw: Association for Computing Machinery. doi:10.1145/1409908.1409942
- Bonneau, J., Herley, C., Oorschot, P., & Stajano, F. (2012). The Quest to Replace Passwords: A Framework for Comparative Evaluation of Web Authentication Schemes. In *2012 IEEE Symposium on Security and Privacy* (pp. 553-567). San Francisco. doi:10.1109/SP.2012.44
- Cialdini, R. (1984). *Influence: The Psychology of Persuasion*. HarperBus.
- Cornell University. (n.d.). *Authentication of Humans*. Retrieved from Cornell University: https://www.cs.cornell.edu/courses/cs5430/2015sp/notes/authen_humans.php
- DogTownMedia. (2026, January 27). *Two-Factor Authentication (2FA): SMS vs. Authenticator Apps for Your Corporate Security*. Retrieved from DogTownMedia: <https://www.dogtownmedia.com/two-factor-authentication-2fa-sms-vs-authenticator-apps-for-your-corporate-security/>
- Jagatic, T. N., Johnson, N. A., Jakobsson, M., & Menczer, F. (2007, October). Social phishing. *Communications of the ACM*, 50(10), 94-100. doi:10.1145/1290958.1290968
- Jalali, M., Bruckes, M., Westmattelmann, D., & Schewe, G. (2020). Why Employees (Still) Click on Phishing Links: Investigation in Hospitals. *Journal of Medical Internet Research*, 22(1). doi:10.2196/16775
- Lamport, L. (1981). Password authentication with insecure communication. In *Commun. ACM* (Vol. 24, pp. 770-772). New York: Association for Computing Machinery. doi:10.1145/358790.358797
- Microsoft. (n.d.). *What is phishing?* Retrieved from Microsoft: <https://www.microsoft.com/en-gb/security/business/security-101/what-is-phishing#:~:text=Phishing%20is%20a%20type%20of,messages%20designed%20to%20look%20authentic.>
- National Cyber Security Centre. (2019, July 11). *Password administration for system owners*. Retrieved from National Cyber Security Center: <https://www.ncsc.gov.uk/collection/passwords/updating-your-approach>
- National Cyber Security Centre. (2024, September 26). *Multi-factor authentication for your corporate online services*. Retrieved from NCSC: <https://www.ncsc.gov.uk/collection/mfa-for-your-corporate-online-services/avoiding-mfa-anti-patterns>

- Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). *Technical Guide to Information Security Testing and Assessment*. National Institute of Standards and Technology, Gaithersburg. doi:10.6028/NIST.SP.800-115
- Statista Research Department. (2026, April 21). *Number of phishing attacks detected worldwide from 3rd quarter 2013 to 4th quarter 2025*. Retrieved from Statista: <https://www.statista.com/statistics/266155/number-of-phishing-attacks-worldwide/>
- Temoshok, D., Fenton, J., Choong, Y.-Y., Lefkovitz, N., Regenscheid, A., Galluzzo, R., & Richer, J. (2025). *Digital Identity Guidelines: Authentication and Authenticator Management*. National Institute of Standards and Technology, U.S. Department of Commerce. National Institute of Standards and Technology. doi:10.6028/NIST.SP.800-63B-4
- Vigliarolo, B. (2024, June 10). *Snowflake tells customers to enable MFA as investigations continue*. Retrieved from TheRegister: <https://www.theregister.com/security/2024/06/10/snowflake-tells-all-customers-to-turn-on-mfa-after-breach/1102711>
- Which? (2022, December). *The psychology of scams*. Retrieved April 29, 2026, from Which?: <https://media.product.which.co.uk/prod/files/file/gm-c66f3d70-3928-4dee-bb8b-481405be2b5e-the-psychology-of-scams-understanding-why-consumers-fall-for-app-scams.pdf>